

Responsible Disclosure

Ethical Hacking

Recent news & discussions

- Recent vulnerability disclosures?
- Recent bug bounty payouts?
- Recent 0-day disclosures?
- Recent vendor responses (good or bad)?
- Recent legal cases involving security researchers?
- Correlate disclosure with ethical framework (was it handled properly?)

What is Responsible Disclosure?

Core concepts and principles

Definition & Key Concepts

- Responsible Disclosure: The process of reporting security vulnerabilities to vendors privately before public release
- Also known as "Coordinated Vulnerability Disclosure" (CVD)
- Key stakeholders: Researcher, Vendor, and the Public
- Primary goal: Allow time to fix vulnerabilities before exploitation
- Balance between: Security, Transparency, and Timeliness

The Disclosure Spectrum

- Full Disclosure: Immediate public release of vulnerability details
- Coordinated/Responsible Disclosure: Notify vendor first, agree on timeline
- Non-Disclosure: Keep vulnerability private (sell to vendor or government)
- Bug Bounty Programs: Formalized reporting with rewards
- Each approach has ethical implications and trade-offs

Standard Timeline & Process

- Step 1: Discovery and thorough documentation of vulnerability
- Step 2: Initial vendor contact (use encrypted channels if possible)
- Step 3: Negotiate disclosure timeline (typically 90 days industry standard)
- Step 4: Vendor develops, tests, and releases patch
- Step 5: Coordinated public disclosure with CVE assignment
- Step 6: Post-disclosure support and follow-up

Bug Bounty Programs

Bug Bounty Overview

- Formalized vulnerability reporting programs with defined scope
- Major platforms: HackerOne, Bugcrowd, Synack, Intigriti
- Scope document defines what systems you CAN test
- Rewards: Cash (\$100 to \$1M+), swag, recognition, CVE credits
- Safe harbor provisions protect good-faith researchers
- Participants: Google, Microsoft, Apple, Meta, government agencies

Legal Considerations

- Computer Fraud and Abuse Act (CFAA) - primary US federal law
- Safe harbor provisions in bug bounty programs provide legal protection
- Good faith research protections (DOJ 2022 policy update)
- Authorization vs. unauthorized access - the key legal distinction
- International laws vary significantly (UK, EU, etc.)
- Documentation is critical - always maintain detailed records

Case Studies

Learning from real-world disclosures

Notable Disclosure Examples

- Google Project Zero: Established 90-day disclosure policy
- Heartbleed (CVE-2014-0160): Coordinated disclosure success story
- Log4Shell: Rapid timeline due to active exploitation
- Microsoft Patch Tuesday: Industry coordination model
- Darknet Diaries episodes: Real researcher stories
- Both good and problematic disclosure examples exist

What Makes Good Disclosure?

- Clear, detailed vulnerability report with reproduction steps
- Proof of concept that is non-destructive (don't cause damage)
- Professional, courteous communication throughout
- Reasonable timeline expectations (understand patch complexity)
- Coordinated release date agreed upon by all parties
- Post-disclosure availability for follow-up questions

Activity

Activity: Darknet Diaries Analysis

- Listen to assigned Darknet Diaries episode featuring disclosure
- Identify the disclosure method used by the researcher
- Analyze: Was the disclosure handled appropriately? Why or why not?
- What could have been done differently by researcher or vendor?
- Discuss ethical considerations and legal implications
- Submit written analysis to Blackboard

Resources & Further Reading

- CERT/CC Vulnerability Disclosure Guidelines
- ISO 29147 - Vulnerability Disclosure Standard
- HackerOne & Bugcrowd Disclosure Guidelines
- disclose.io - Safe harbor language templates
- Darknet Diaries podcast - Real stories from researchers
- DOJ Policy on Good Faith Security Research (2022)

Homework

- Listen to the following Darknet Diaries Podcasts
- [EP 86: The LinkedIn Incident](#)
- [EP 87: Guild of the Grumpy Old Hackers](#)
- [EP 88: Victor](#)
- Unit 15 Assignment - Responsible Disclosure (Due December 8th, 11:59pm)
- Unit 16 Assignment - Final Thoughts (Due December 12th, 11:59pm)